

INFORME DE SEGURIDAD Y CALIDAD

EN EL DESARROLLO DE SOFTWARE

Plan de Pruebas — Sistema de Gestión Atlas

Evaluación Parcial N.º 1 · ISY1102

Carrera: Ingeniería en Desarrollo de Software

Asignatura: Seguridad y Calidad en el Desarrollo de Software (ISY1102)

Sección: 002V

Docente: Christian Rodrigo Alvarez Lobos

Fecha de entrega: [completar]

Integrantes:

Luis Tasso

Miguel Arredondo

Nicolas Iturrieta

Contenido

1. Introducción	3
2. Criterios de calidad, seguridad y cumplimiento normativo	3
2.1 Calidad del producto	3
2.2 Seguridad	4
2.3 Cumplimiento normativo	4
3. Marco de referencia y estándares aplicables	5
4. Plan de pruebas	6
4.1 Objetivos del plan de pruebas	6
4.2 Alcance del plan de pruebas	6
4.3 Estrategia de pruebas	7
4.4 Tipos de prueba y justificación	8
4.5 Criterios de aceptación (transversales)	8
4.6 Herramientas utilizadas	9
4.7 Cronograma de ejecución del plan de pruebas	9
5. Recursos necesarios para la ejecución de pruebas	10
6. Diseño de casos de prueba	11
7. Matriz de trazabilidad	14
8. Análisis de cobertura del plan (IE5)	14
9. Conclusiones del análisis preliminar	15
10. Referencias	16
10. Evidencias	17

1. Introducción

Contexto del sistema a evaluar. Atlas es una plataforma web de gestión de clientes y contratos orientada a pequeñas y medianas empresas (pymes) de Chile. El sistema se estructura en tres capas: un *frontend* construido con React y Material UI (SPA responsiva), un *backend* con Express/Node.js que expone una API REST, y una base de datos PostgreSQL. Permite a usuarios registrados por empresa gestionar clientes, contratos y documentos asociados, administrar usuarios y roles (administrador/editor), auditar acciones críticas y gestionar el ciclo de vida de los contratos.

El proyecto se entrega como *código fuente* (Caso A) sobre el cual el equipo de QA debe diseñar un plan de pruebas que asegure su calidad, seguridad y conformidad normativa antes de su puesta en producción.

Propósito del plan. El objetivo de este plan es definir la estrategia, los recursos, el alcance y el diseño de los casos de prueba necesarios para verificar que Atlas cumple con los requisitos funcionales y no funcionales descritos en la Especificación de Requerimientos de Software (ERS), así como con los estándares de calidad (ISO/IEC 25010), seguridad de la información (ISO/IEC 27001) y la normativa chilena de protección de datos personales (Ley 19.628 y Ley 21.719). Se busca asegurar que el software sea funcionalmente correcto, seguro, accesible, transversalmente legal y auditable.

Contenido y estructura del informe. El documento se organiza en: criterios de calidad, seguridad y cumplimiento normativo; plan de pruebas (estrategia, tipos de prueba, criterios de aceptación y herramientas); recursos necesarios; y diseño de casos de prueba representativos con su trazabilidad a los requerimientos del ERS.

2. Criterios de calidad, seguridad y cumplimiento normativo

Se establecen los estándares que el sistema debe satisfacer, tomando como base el ERS del Sistema Atlas y los marcos normativos aplicables al contexto chileno.

2.1 Calidad del producto

Según el modelo ISO/IEC 25010 (SQuaRE), Atlas debe cumplir con las siguientes características y subcaracterísticas:

- Adecuación funcional: las operaciones de autenticación, gestión de clientes, contratos, documentos, usuarios/roles y auditoría deben implementar correctamente los requisitos RF-1 a RF-6.
- Usabilidad y accesibilidad: interfaz responsiva (desktop, tablet, móvil), tipografía de tamaño de fuente 12 px, contraste suficiente, etiquetas ARIA, navegación por teclado y controles de tamaño mínimo para pantallas táctiles, con especial atención a usuarios adultos mayores (NFR-USAB).
- Rendimiento: tiempos de respuesta de operaciones CRUD menores a 300 ms bajo carga normal, carga de página principal menor a 2 s y soporte de 200 usuarios concurrentes (NFR-PERF).
- Estabilidad y confiabilidad: disponibilidad objetivo 99,5 % mensual (NFR-DIS-1) y tolerancia a fallos sin pérdida de datos.
- Mantenibilidad: código legible, modular y documentado en frontend y backend.

2.2 Seguridad

Conforme a ISO/IEC 27001 y a los requerimientos NFR-SEG del ERS:

- Confidencialidad: cifrado de comunicaciones (TLS), cifrado de datos sensibles en reposo y control de acceso por roles.
- Integridad: hashing seguro de contraseñas (bcrypt) y validación/saneamiento de entradas para prevenir inyección SQL, XSS y CSRF.
- Disponibilidad: políticas de respaldo (backup) y recuperación (NFR-SEG-7), gestión de logs segura (NFR-SEG-6) y manejo de sesión mediante token JWT de corta vigencia (NFR-SEG-9).
- Autenticación y autorización: autenticación con credenciales, revocación de sesión y control de acceso por rol en el backend (RB-2, RB-4, RB-5).

2.3 Cumplimiento normativo

- Ley 19.628 (Protección de Datos Personales) y Ley 21.719: Atlas trata datos personales y bancarios de clientes. Se exige consentimiento explícito e informado, minimización de datos, cifrado, control de acceso, trazabilidad y respeto al plazo de conservación de los datos.

- ISO/IEC 27001: gestión de la seguridad de la información alineada con los controles del SGSI.
- ISO/IEC 25010: marco de calidad del producto.
- Accesibilidad e inclusión digital: cumplimiento básico de estándares WCAG y normativa de inclusión, evitando discriminación de usuarios con discapacidad.

3. Marco de referencia y estándares aplicables

Para garantizar la calidad del proceso y la coherencia con la industria, el plan de pruebas se basa en los siguientes marcos y normas:

- ISO/IEC/IEEE 29119 (Ingeniería de software — Pruebas de software): establece el proceso de pruebas (política, estrategia, diseño, ejecución y gestión de incidentes) y la terminología de los tipos de prueba y casos de prueba utilizados en este informe.
- ISO/IEC 25010 (SQuaRE): modelo de calidad del producto que define las características de adecuación funcional, rendimiento, usabilidad, seguridad, compatibilidad, mantenibilidad y confiabilidad evaluadas en los criterios de la sección 2.1.
- ISO/IEC 27001 (SGSI): referente de seguridad de la información; sus controles del Anexo A (A.9.4 Control de acceso, A.10 Criptografía, A.12.4 Registro de actividad, A.18.1 Requisitos legales) sustentan los criterios de seguridad y auditoría del plan.
- OWASP Top 10: identifica los riesgos de seguridad web más relevantes (control de acceso roto, malas configuraciones, fallas criptográficas, inyección) que orientan las pruebas de seguridad dinámicas y estáticas (sección 4.4 y casos CP-02 y CP-05).
- ISTQB (International Software Testing Qualifications Board): sus fundamentos de pruebas (niveles de prueba, técnicas de diseño de casos, criterios de entrada/salida) estructuran la estrategia y la ejecución descritas en la sección 4.3.
- Ley 19.628 y Ley 21.719 (Chile): protección y tratamiento de datos personales, que condicionan los criterios de cumplimiento normativo (sección 2.3) y los casos de prueba orientados a la protección de datos sensibles.

El uso coordinado de estos marcos garantiza trazabilidad entre los criterios (sección 2), la estrategia (sección 4) y los casos de prueba diseñados (sección 6), fortaleciendo el respaldo técnico del plan frente a la evaluación (criterio de coherencia y marco profesional).

4. Plan de pruebas

4.1 Objetivos del plan de pruebas

Objetivo general: verificar que el Sistema de Gestión Atlas cumple con los requerimientos funcionales y no funcionales definidos en el ERS, garantizando su calidad, seguridad y conformidad con la normativa vigente de protección de datos, antes de su puesta en producción.

Objetivos específicos:

- Validar el correcto funcionamiento de los módulos de autenticación, clientes, contratos, documentos, usuarios/roles y auditoría (RF-1 a RF-6).
- Comprobar la cobertura de los criterios de rendimiento (NFR-PERF), seguridad (NFR-SEG), usabilidad y accesibilidad (NFR-USAB) y compatibilidad (NFR-COMPAT).
- Detectar y evidenciar vulnerabilidades de seguridad del código fuente (control de acceso, cifrado, secretos) antes de la liberación.
- Demostrar la trazabilidad entre requerimientos, casos de prueba y resultados para sustentar auditorías de cumplimiento.

4.2 Alcance del plan de pruebas

Dentro del alcance:

- Módulos funcionales de Atlas: autenticación y sesión, registro de usuarios y creación de empresa, gestión de clientes, contratos y documentos, usuarios y roles, y registro de auditoría.
- Requisitos no funcionales de seguridad, rendimiento, usabilidad, accesibilidad, disponibilidad y compatibilidad definidos en el ERS.
- Análisis de calidad y seguridad del código fuente provisto (Caso A).

Fuera del alcance:

- Pruebas sobre sistemas externos no provistos en el caso (pasarelas de pago u otros servicios de terceros no incluidos).

- Pruebas de aceptación de usuarios finales en producción.
- Modificaciones correctivas del código (solo se reportan los hallazgos).

4.3 Estrategia de pruebas

Enfoque: mixto (manual y automatizado). Se combina la ejecución manual para pruebas exploratorias y de usabilidad con la automatización de pruebas funcionales, de regresión, de rendimiento y de seguridad.

Etapas del proceso:

2. Definición del alcance y lecturas del ERS y del código fuente.
3. Diseño de casos de prueba con trazabilidad a requerimientos.
4. Preparación del entorno de pruebas (backup del ambiente de datos real).
5. Ejecución de pruebas funcionales (CRUD de clientes, contratos, usuarios, autenticación, auditoría).
6. Ejecución de pruebas no funcionales (rendimiento, carga, usabilidad y accesibilidad).
7. Ejecución de pruebas de seguridad (análisis estático y dinámico, penetración).
8. Registro de resultados, análisis y generación de evidencias para auditoría.

Herramientas a utilizar:

- Análisis estático: SonarQube / ESLint (frontend) y revisión manual del backend.
- Funcionales: Postman (validación de la API REST) y Selenium (interfaz web).
- Rendimiento y carga: JMeter y/o Locust (simulación de usuarios concurrentes).
- Seguridad: OWASP ZAP (escaneo de vulnerabilidades), escaneo de dependencias.
- Gestión de casos: TestRail o documentación Markdown versionada en Git.

Priorización de pruebas: se priorizan por impacto y riesgo, dando prioridad alta a autenticación (RF-1), gestión de clientes (RF-4), contratos/documentos (RF-5), auditoría (RF-6) y a los controles de seguridad y control de acceso.

Criterios de entrada: el sistema debe estar desplegado (Docker o manual), con base de datos inicializada y datos de prueba cargados; los casos de prueba deben estar diseñados y revisados.

Criterios de salida: todos los casos de prueba críticos (P1/P2) ejecutados; defectos críticos corregidos y verificados; sin vulnerabilidades críticas por medio de los escaneos; evidencias documentadas y trazables a los requerimientos.

4.4 Tipos de prueba y justificación

- Pruebas funcionales (¿qué hace?): verifican que cada operación del sistema cumple el requisito. Validan login, registro de usuario y creación de empresa, CRUD de clientes, creación/edición/eliminación de contratos, carga y descarga de documentos, gestión de usuarios y roles, y registro de auditoría.
- Pruebas no funcionales (¿cómo lo hace?):
- Rendimiento: tiempos de respuesta de los CRUD y carga de la página principal contra los umbrales NFR-PERF.
- Carga: comportamiento con 200 usuarios concurrentes (NFR-PERF-3).
- Seguridad: escaneo y pruebas de penetración contra NFR-SEG; control de acceso por rol y protección contra SQL injection, XSS y CSRF.
- Usabilidad: evaluación con usuarios, incluidos adultos mayores, y cumplimiento de accesibilidad (NFR-USAB).
- Compatibilidad: última versión de navegadores modernos y dispositivos móviles/tablets (NFR-COMPAT).
- Pruebas de integración: verificación de que el frontend React, la API Express y la base de datos PostgreSQL interactúan correctamente (flujo completo cliente → contrato → documento).
- Pruebas de seguridad: análisis estático (revisión de código), análisis dinámico (OWASP ZAP) y pruebas de penetración específicas sobre los hallazgos del código fuente.

4.5 Criterios de aceptación (transversales)

Un caso de prueba se considera aprobado cuando:

- Funcional: la acción produce el resultado esperado sin errores; la respuesta es correcta en formato y contenido; el registro de auditoría se genera para las acciones críticas.

- No funcional: el endpoint CRUD responde en menos de 300 ms bajo carga normal; la página principal carga en menos de 2 s; el sistema soporta 200 usuarios concurrentes sin degradación significativa; los tiempos de subida/descarga de documentos no superan los 10 s (RF-5).
- Seguridad: no se detectan vulnerabilidades críticas (SQL injection, XSS, CSRF, acceso no autorizado a recursos de otras empresas) y el control de acceso por rol funciona correctamente.
- Reglas de negocio: se respetan RB-2 (solo usuarios vinculados ven datos de la empresa), RB-3 (un contrato se asocia a un solo cliente), RB-4 (editor solo lectura) y RB-5 (administrador con control completo).

4.6 Herramientas utilizadas

Herramienta	Uso en el plan	Justificación
Postman	Validación de la API REST en todos los endpoints	Permite probar autenticación, métodos, parámetros y cabeceras de la API de forma rápida y reproducible
Selenium	Pruebas funcionales de la interfaz web	Automatiza flujos de usuario en el navegador y permite regresión
JMeter / Locust	Pruebas de rendimiento y carga	Simula 200 usuarios concurrentes y mide tiempos de respuesta del sistema
OWASP ZAP	Pruebas de seguridad dinámica	Escanea vulnerabilidades web (inyección, XSS, configuraciones inseguras)
SonarQube / ESLint	Análisis estático de código	Detecta malas prácticas, vulnerabilidades y deuda técnica en frontend y backend
Docker	Despliegue del entorno	Reproduce el ambiente completo (frontend, backend, PostgreSQL) de forma aislada y reproducible

4.7 Cronograma de ejecución del plan de pruebas

La ejecución de las pruebas se distribuye de la siguiente forma, dentro de las 3 horas pedagógicas asignadas al encargo:

Etapa	Actividad	Duración estimada	Entregable
-------	-----------	-------------------	------------

Preparación	Despliegue del entorno (Docker), carga de datos de prueba y revisión del ERS	30 min	Entorno QA operativo
Diseño	Definición y revisión de los casos de prueba y su trazabilidad con requerimientos	40 min	Casos CP-01 a CP-05 definidos
Ejecución funcional	Pruebas funcionales de autenticación, clientes, contratos, usuarios y auditoría	50 min	Resultados funcionales registrados
Ejecución no funcional	Pruebas de rendimiento/carga, usabilidad y compatibilidad	30 min	Métricas y reportes
Ejecución de seguridad	Análisis estático, escaneo dinámico (OWASP ZAP) y verificación de control de acceso	20 min	Hallazgos de vulnerabilidades
Documentación	Consolidación de resultados, evidencias y elaboración del informe final	10 min	Informe final para entrega en AVA

5. Recursos necesarios para la ejecución de pruebas

- Recursos humanos: un líder de QA / ingeniero de calidad, un tester funcional, un tester de seguridad y un tester de rendimiento; colaboración con el equipo de desarrollo para la corrección de defectos y con el área legal para la validación del cumplimiento normativo.
- Recursos técnicos: equipos con Node.js, npm, Docker, Git y navegadores modernos; herramientas de prueba (Postman, Selenium, JMeter/Locust, OWASP ZAP, SonarQube); entorno de desarrollo y de QA aislado de producción.
- Entorno de prueba: ambiente QA local (Docker) con datos de prueba ficticios de clientes, contratos y usuarios; no utilizar datos reales para evitar comprometer información personal.

6. Diseño de casos de prueba

A continuación se presentan cinco casos de prueba representativos que cubren requerimientos funcionales y no funcionales del ERS. Cada caso detalla ID, descripción, requerimiento asociado, precondiciones, pasos, resultado esperado, criterio de aceptación y datos de prueba. El detalle por caso se presenta en formato tabular para su lectura y trazabilidad.

CP-01 · Inicio de sesión y obtención de token (Autenticación)

Campo	Detalle
ID	CP-01
Nombre	Login exitoso con credenciales válidas
Requerimiento	RF-1.1 (El sistema debe permitir autenticarse con nombre_usuario y contraseña)
Tipo de prueba	Funcional
Descripción	Verificar que un usuario autenticado obtiene un token de sesión y accede al sistema
Precondiciones	Existir un usuario registrado en la base de datos; backend y frontend desplegados
Pasos	1. Enviar `POST /autenticacion/login` con `{nombre_usuario, password}` válidos. 2. Verificar código 200 y presencia de `token`. 3. Reintentar con credenciales inválidas y verificar 401.
Datos de prueba	usuario: `admin1`, password: `Clave#12345` (y variante inválida)
Resultado esperado	Con credenciales válidas: HTTP 200 y token JWT. Con credenciales inválidas: HTTP 401 "Credenciales inválidas"
Criterio de aceptación	Login exitoso genera un token de sesión (JWT); login con credenciales incorrectas es rechazado (RF-1)
Observación	El código compara la contraseña en texto plano (`contrasena_hash !== password`) en lugar de bcrypt; se recomienda corregir el almacenamiento seguro

CP-02 · Control de acceso por rol (Editor solo lectura)

Campo	Detalle
ID	CP-02
Nombre	Bloqueo de operaciones de escritura para rol editor
Requerimiento	RF-3.2 / RB-4 (El rol editor solo permite visualización; un editor no puede crear, editar ni eliminar)
Tipo de prueba	Funcional / Seguridad

Descripción	Verificar que un usuario con rol editor no puede crear ni eliminar clientes, mientras un administrador sí puede
Precondiciones	Un usuario administrador y un usuario editor en la misma empresa; token de cada uno
Pasos	1. Con token de editor, enviar `POST /clientes`. 2. Verificar que la operación es denegada (403/401). 3. Con token de administrador, enviar el mismo `POST /clientes` y verificar 201.
Datos de prueba	cliente: `{nombre, correo, telefono}` con token editor y token admin
Resultado esperado	El editor no puede crear clientes; el administrador sí puede
Criterio de aceptación	Los usuarios con rol editor no acceden a creación, edición o eliminación; solo lectura (RF-3.2, RB-4)
Observación	El backend valida la existencia del token y de `empresald`, pero no distingue el rol (admin/editor) al momento de autorizar; el control de roles está delegado al frontend (`RoleGuard`), por lo que puede ser omitido si se llama a la API directamente — hallazgo de seguridad

CP-03 · Cobertura de auditoría de acciones críticas (Trazabilidad)

Campo	Detalle
ID	CP-03
Nombre	Registro de auditoría al crear un cliente
Requerimiento	RF-6.1 (Registrar en auditoría la creación, edición, eliminación de clientes, contratos, usuarios y subida/descarga de documentos)
Tipo de prueba	Funcional
Descripción	Verificar que al crear/editar/eliminar un cliente se genera un registro en la tabla de auditoría
Precondiciones	Usuario autenticado con token válido con empresa asociada
Pasos	1. Crear un cliente mediante `POST /clientes`. 2. Consultar `GET /auditoria`. 3. Verificar que existe un registro con la acción correspondiente.
Datos de prueba	nombre: `Cliente Prueba`, correo: `cliente@test.cl`
Resultado esperado	Existe un registro de auditoría con la acción `CLIENTES CREAR: creó cliente ...`
Criterio de aceptación	Se genera un registro de auditoría por cada acción crítica (RF-6)
Observación	El endpoint `GET /auditoria` no valida autenticación y expone el registro completo de todas las empresas — fuga de información (IDOR). Ver CP-05

CP-04 · Rendimiento de listado de clientes ante carga concurrente

Campo	Detalle
ID	CP-04
Nombre	Tiempo de respuesta de consulta CRUD bajo carga (200 usuarios)
Requerimiento	NFR-PERF-1 (respuesta CRUD < 300 ms bajo carga normal) y NFR-PERF-3 (200 usuarios concurrentes)
Tipo de prueba	No funcional (Rendimiento / Carga)
Descripción	Medir el tiempo de respuesta del endpoint de listado de clientes con una carga de usuarios concurrentes
Precondiciones	Sistema desplegado con datos de prueba; herramienta de carga (JMeter/Locust) configurada
Pasos	1. Configurar una prueba de carga con 200 usuarios virtuales. 2. Ejecutar `GET /clientes` repetidamente. 3. Registrar tiempos de respuesta promedio y percentiles (p90/p95).
Datos de prueba	200 usuarios concurrentes; dataset de 1.000 clientes
Resultado esperado	El tiempo de respuesta debe ser menor a 300 ms bajo carga normal
Criterio de aceptación	El sistema cumple el umbral de NFR-PERF-1 y soporta 200 usuarios concurrentes (NFR-PERF-3)
Observación	El código incluye `delay(4000)` (simula latencia de 4 s) en login, listado de clientes y contratos; esto **hace fallar** NFR-PERF-1/NFR-PERF-2, por lo que la prueba debe detectar la degradación

CP-05 · Acceso no autorizado a recursos de otra empresa (Seguridad/Broken Access Control)

Campo	Detalle
ID	CP-05
Nombre	Prevención de acceso no autorizado a contratos y auditoría
Requerimiento	NFR-SEG-4 (Control de acceso por rol en backend), NFR-SEG-9 (sesión mediante JWT), RB-2 (solo usuarios vinculados ven los datos de empresa)
Tipo de prueba	No funcional (Seguridad)
Descripción	Verificar que un usuario no puede acceder a los documentos de un contrato ni al registro de auditoría de otra empresa sin autorización
Precondiciones	Dos empresas distintas (A y B) con clientes y contratos; token del usuario de la empresa A

Pasos	1. Con token de empresa A, solicitar `GET /contratos/{id}/file` de un contrato de la empresa B. 2. Solicitar `GET /auditoria` sin token. 3. Verificar códigos de respuesta.
Datos de prueba	id de contrato de la empresa B; petición `GET /auditoria` sin cabecera Authorization
Resultado esperado	El acceso al documento de otra empresa debe denegarse (403/404); la consulta de auditoría sin token debe denegarse
Criterio de aceptación	No hay acceso a recursos de otras empresas ni a datos sensibles sin autenticación (NFR-SEG-4, RB-2)
Observación	Los endpoints `GET /contratos/:id/file`, `DELETE /contratos/:id` y `GET /auditoria` **no validan autenticación ni pertenencia a la empresa** , permitiendo leer documentos y auditoría de terceros, y eliminar contratos — hallazgo crítico de seguridad

7. Matriz de trazabilidad

La siguiente matriz vincula cada caso de prueba con los requerimientos del ERS y los criterios de calidad/seguridad, garantizando cobertura bidireccional (cada requerimiento crítico cuenta con al menos un caso que lo valida).

Caso de prueba	Requerimiento ERS	Tipo de prueba	Objetivo validado
CP-01	RF-1 · RF-1.1	Funcional	Autenticación y emisión de token de sesión
CP-02	RF-3.2 · RB-4 · NFR-SEG-4	Funcional / Seguridad	Control de acceso por rol en el backend
CP-03	RF-6 · RF-6.1	Funcional	Registro de auditoría de acciones críticas
CP-04	NFR-PERF-1 · NFR-PERF-2 · NFR-PERF-3	No funcional (Rendimiento / Carga)	Cumplimiento de umbrales de rendimiento
CP-05	NFR-SEG-4 · NFR-SEG-9 · RB-2	No funcional (Seguridad)	Prevención de acceso no autorizado y Broken Access Control

8. Análisis de cobertura del plan (IE5)

El plan de pruebas diseñado da cobertura a los requerimientos funcionales y no funcionales del ERS y a los estándares técnicos y legales aplicables, de la siguiente forma:

- Cobertura funcional: los cinco casos abarcan los seis módulos de RF-1 a RF-6 (autenticación, usuarios/empresas, clientes, contratos/documentos, usuarios y roles, y auditoría), priorizando las funciones críticas de negocio.
- Cobertura no funcional: se incorporan pruebas de rendimiento y carga (NFR-PERF), seguridad (NFR-SEG), usabilidad y accesibilidad (NFR-USAB), compatibilidad (NFR-COMPAT) y disponibilidad (NFR-DIS) en la estrategia y en los casos CP-04 y CP-05.
- Cobertura de reglas de negocio: las reglas RB-2 (acceso por vinculación a empresa), RB-3 (un contrato por cliente), RB-4 (editor solo lectura) y RB-5 (administrador con control completo) se verifican explícitamente en CP-02 y CP-05.
- Cobertura normativa: los criterios de la sección 2.3 (Ley 19.628, Ley 21.719, ISO/IEC 27001, ISO/IEC 25010, WCAG) se traducen en criterios de aceptación transversales (sección 4.5) y en observaciones de cumplimiento de cada caso.
- Trazabilidad y evidencia: cada caso referencia el código del requerimiento en el ERS y registra el resultado esperado y la observación de hallazgos, lo que permite auditoría del proceso de pruebas y sustentar la liberación del software.

Como resultado, el plan cubre de manera balanceada las dimensiones de calidad, seguridad y cumplimiento normativo exigidas por la evaluación, y los hallazgos preliminares del código fuente (sección 9) demuestran su necesidad y aplicabilidad real al caso.

9. Conclusiones del análisis preliminar

El sistema Atlas presenta una base funcional clara y un ERS bien definido, pero el análisis del código fuente revela hallazgos de seguridad relevantes que el plan de pruebas debe validar y que requieren corrección previa a producción:

9. Contraseñas almacenadas y comparadas en texto plano en `auth.js` (se usa `contrasena_hash` como campo, pero se compara contra el texto sin aplicar `bcrypt`), lo que incumple NFR-SEG-2.
10. Control de acceso deficitario: varios endpoints (crear contrato, `GET /:id`, `GET /:id/file`, `DELETE /:id`, listar empresas, roles, auditoría) no validan autenticación ni pertenencia a la empresa ni el rol, habilitando accesos no autorizados, lectura de documentos de otras empresas e incluso la eliminación de contratos (IDOR

/ Broken Access Control). El control de rol (admin/editor) está delegado únicamente al frontend.

11. Secretos expuestos: el `JWT_SECRET` está comprometido en el archivo `.env` del repositorio, lo que permite falsificar tokens y comprometer toda la autenticación.
12. Latencia artificial de 4 segundos (`delay(4000)`) en operaciones CRUD, que haría fallar los criterios de rendimiento NFR-PERF-1 / NFR-PERF-2 de no eliminarse antes de producción.
13. CORS abierto (`app.use(cors())`) sin restricción de orígenes, ampliando la superficie de ataque (CSRF).

Estos hallazgos demuestran la necesidad del plan de pruebas aquí diseñado y sirven de evidencia para el apartado de cobertura y coherencia frente a estándares técnicos y legales del informe.

10. Referencias

- ISO/IEC 25010:2011, Systems and software engineering — Systems and software Quality Requirements and Evaluation (SQuaRE) — System and software quality models.
- ISO/IEC 27001:2022, Information security, cybersecurity and privacy protection — Information security management systems — Requirements.
- ISO/IEC/IEEE 29119, Software and systems engineering — Software testing (Parts 1, 2 y 3).
- OWASP Foundation, OWASP Top 10:2021, A01 Broken Access Control; A02 Cryptographic Failures; A07 Identification and Authentication Failures.
- ISTQB, International Software Testing Qualifications Board — Foundation Level Syllabus (CTFL).
- Ley N.º 19.628, Sobre protección de la vida privada (Chile, 1999).
- Ley N.º 21.719, Modifica la Ley 19.628 para adecuar la normativa nacional a los estándares internacionales en materia de protección de datos personales (Chile, 2024).
- Especificación de Requerimientos de Software (ERS) — Sistema de Gestión Atlas (Caso A), material entregado en la evaluación.

10. Evidencias

ATLAS

Inicio

Cientes

Contratos

Auditoria

Usuarios

admin

Administrador

Editar cuenta

Cerrar Sesión

Versión 1.0.0

Bienvenido, admin

2

Usuarios de la Empresa

2

Clientes Creados

0

Vencen en 15 días

0

Vencen en 30 días

Editar Empresa

Actualiza la información de tu empresa: nombre, dirección, teléfono y correo.

Editar Empresa

Editar Usuario

Camia tu contraseña y actualiza tu información de usuario.

Editar Usuario

PRÓXIMOS A VENCER

VENCIDOS

No hay contratos próximos a vencer

Actualmente no existen contratos que estén próximos a vencer en los próximos días.

ATLAS

Inicio

Cientes

Contratos

Auditoria

Usuarios

admin

Administrador

Editar cuenta

Cerrar Sesión

Versión 1.0.0

Gestión de Clientes

Administra la información de tus clientes. Puedes crear, editar y eliminar clientes según tus permisos.

LISTAR CLIENTES

CREAR CLIENTE

Clientes registrados

El siguiente listado muestra todos los clientes registrados en el sistema. Puedes editar y eliminar clientes según tus permisos.

Nombre	Correo	Teléfono	Dirección	Acciones
Pedro Morales	pedro.morales@constructoraandes.cl	998877665	Av. Apoquinda 4500, Las Condes, Santiago	Editar Eliminar
Maria González	mario.gonzalez@biotec.cl	987654321	Av. Providencia 1234, Providencia, Santiago	Editar Eliminar

Filas por página 10 1-2 de 2

ATLAS

Iniciar Sesión

Nombre de usuario

Contraseña

Entrar

¿No tienes cuenta?

Regístrate

Guía Inicial

ATLAS

Inicio

Cientes

Contratos

Auditoría

Usuarios

editor

Administrador

Editar cuenta

Cerrar Sesión

Version 1.0.0

Gestión de Contratos

Administra todos los contratos de tus clientes. Puedes crear, editar y visualizar contratos según tus permisos.

LISTAR CONTRATOS

CREAR CONTRATO

Contratos registrados

El siguiente listado muestra todos los contratos registrados en el sistema. Puedes ver los detalles haciendo clic en cada fila.

Título	Cliente	Inicio	Fin	Estado	Archivo	Acciones
Contrato de Servicios	Pedro Morales	31 dic 2025	30 dic 2026	Vigente	Ver archivo	
Contrato de Servicios	Maria Gonzalez	31 dic 2025	30 dic 2026	Vigente	Ver archivo	

Filas por página 101-2 de 2